EXPOSÉ DE CYBERSÉCURITÉ

Nmap : Analyse et Sécurisation du Réseau à travers la Cartographie et la Détection des Vulnérabilités

Groupe 2 :

ALI Gnilim Tabitha
BAGNA Mourchidah
BOKONAO Boyoda Elizam Dora
MIVEDOR Ayi Bismark
GAVI Israël
BABA Fayçal
TCHAKEBERA Gabriella
MANGAMANA Pidenam

Professeur : M. BOUKLINAM

Année académique 2025-2026

1. Introduction à Nmap

1.1 Définition et historique de Nmap

Nmap (Network Mapper) est un outil open source de scan réseau créé par Gordon Lyon, connu sous le pseudonyme « Fyodor », en 1997. Il fut initialement publié dans le magazine spécialisé Phrack et s'est depuis imposé comme l'un des outils de sécurité informatique les plus utilisés au monde. Disponible sur Linux, Windows et macOS, son code source est entièrement libre et accessible à tous.

Avec Nmap, on désigne le processus d'identification des cibles réseau sous le terme d'Énumération de cibles (Enumeration Target). Lors d'un scan, cette énumération peut prendre plusieurs formes :

- Une liste d'adresses IP : par exemple 10.10.5.10, 10.10.5.12
- Une plage d'adresses : par exemple 10.10.5.10-15 ou 10.10.20-25.10-20
- Un sous-réseau : par exemple 10.10.5.0/24
- Un fichier contenant la liste des cibles : nmap -iL target.txt

Il est également possible de vérifier les cibles que Nmap va utiliser dans son analyse via la commande :

```
nmap -sL <target>
```

1.2 Pourquoi utiliser Nmap en cybersécurité ?

Les réseaux modernes sont complexes : des dizaines, voire des centaines de machines, services et ports peuvent être actifs simultanément. Avant de commencer n'importe quel type d'analyse de sécurité, il est impératif de connaître la cible en question — notamment ses adresses IP et les services qu'elle expose. Nmap permet de répondre aux questions fondamentales suivantes :

- Quelles machines sont actives sur le réseau ?
- Quels ports sont ouverts et potentiellement exposés ?
- Quels services et versions logicielles tournent sur ces ports ?
- Ces services présentent-ils des vulnérabilités connues ?

Sans cet inventaire préalable, il est impossible de sécuriser un réseau de manière rigoureuse et efficace.

1.3 Cas d'usage : audit de sécurité, tests de pénétration, analyse réseau

Cas d'usage	Description
Audit de sécurité	Inventaire complet des services exposés sur le réseau
Test de pénétration	Phase de reconnaissance avant une tentative d'intrusion autorisée
Analyse réseau	Cartographie topologique d'un parc informatique
Conformité	Vérifier qu'aucun port interdit n'est ouvert
Réponse à incident	Identifier rapidement des services suspects ou compromis

2. Découverte d'hôtes actifs avec Nmap

2.1 Le protocole ARP (Address Resolution Protocol)

ARP est un protocole de la couche liaison qui permet de faire la correspondance entre une adresse IP (couche réseau) et une adresse MAC (couche liaison) dans un réseau local. Son fonctionnement est le suivant :

- Lorsqu'un appareil veut communiquer avec un autre sur le même réseau local, il envoie une requête ARP en broadcast.
- La machine ayant l'adresse IP recherchée répond avec son adresse MAC.
- Cette information est ensuite stockée dans le cache ARP pour une utilisation future.

ARP est le moyen le plus fiable pour découvrir les hôtes actifs sur un réseau local car :

- Les requêtes ARP ne peuvent pas être bloquées par un pare-feu.
- Tout appareil connecté au réseau local doit répondre aux requêtes ARP pour fonctionner.
- C'est la méthode par défaut de Nmap quand vous scannez votre réseau local.

Commande Nmap associée :

```
sudo nmap -PR -sn <target>
```

Il existe également un outil complémentaire nommé arp-scan qui permet de réaliser des scans basés sur les requêtes ARP. Exemple :

```
arp-scan -I eth0 192.168.1.0/24
```

2.2 Le protocole ICMP (Internet Control Message Protocol)

ICMP est un protocole de la couche réseau utilisé pour envoyer des messages de contrôle et d'erreur. Il est principalement utilisé pour les diagnostics réseau. Les principaux types de messages ICMP utilisés dans le scan sont :

- Echo Request (Type 8) : utilisé par la commande ping pour tester la connectivité.
- Echo Reply (Type 0) : réponse à un Echo Request.
- Timestamp Request (Type 13) : demande l'heure actuelle.
- Address Mask Request (Type 17) : demande le masque de sous-réseau.

Lorsque Nmap envoie un paquet ICMP de type 8 et obtient une réponse, il considère la machine comme active. Cependant, les paquets ICMP peuvent être bloqués par des pare-feux pour des raisons de sécurité. Les commandes associées sont :

```
sudo nmap -PE -sn <target>   (ICMP Echo Request)
sudo nmap -PP -sn <target>   (ICMP Timestamp Request)
sudo nmap -PM -sn <target>   (ICMP Address Mask Request)
```

2.3 Les protocoles TCP et UDP

TCP (Transmission Control Protocol) et UDP (User Datagram Protocol) sont des protocoles de la couche transport. Ils constituent une alternative quand ARP et ICMP sont bloqués par les pare-feux.

TCP (Transmission Control Protocol) :

- Orienté connexion : établit une connexion avant l'échange de données via le three-way handshake.
- Fiable : garantit la livraison des données dans l'ordre.
- Contrôle de flux : ajuste le débit en fonction de la capacité du réseau.

UDP (User Datagram Protocol) :

- Sans connexion : envoie les données sans établir de connexion préalable.
- Non fiable : pas de garantie de livraison.
- Plus rapide : moins de surcharge que TCP.

Commandes Nmap associées :

```
sudo nmap -PS22,80,443 -sn <target>   (TCP SYN ping)
sudo nmap -PA22,80,443 -sn <target>   (TCP ACK ping)
sudo nmap -PU53,161,162 -sn <target>  (UDP ping)
```

2.4 Tableau récapitulatif des méthodes de découverte

Type de scan	Commande	Particularité
ARP Scan	sudo nmap -PR -sn CIBLE/24	Fiable sur réseau local
ICMP Echo Scan	sudo nmap -PE -sn CIBLE/24	Peut être bloqué par firewall
ICMP Timestamp	sudo nmap -PP -sn CIBLE/24	Alternative à l'Echo
ICMP Addr. Mask	sudo nmap -PM -sn CIBLE/24	Rare, pour anciens systèmes
TCP SYN Ping	sudo nmap -PS22,80,443 -sn	Contourne certains firewalls
TCP ACK Ping	sudo nmap -PA22,80,443 -sn	Mappe les règles firewall
UDP Ping	sudo nmap -PU53,161 -sn	Ports UDP courants

Note importante : ajouter -sn si vous êtes uniquement intéressé par la découverte d'hôtes sans scanner les ports. Omettre -sn fera que Nmap scannera par défaut les ports des hôtes actifs.

3. Scan de ports avec Nmap

3.1 États des ports selon Nmap

Un port peut être identifié selon six états différents par Nmap, en tenant compte de la présence éventuelle de pare-feux :

- Open (Ouvert) : un service écoute et accepte les connexions sur ce port.
- Closed (Fermé) : le port est accessible mais aucun service n'écoute dessus.
- Filtered (Filtré) : Nmap ne peut pas déterminer si le port est ouvert car un pare-feu bloque les paquets.
- Unfiltered (Non filtré) : le port est accessible mais Nmap ne peut pas déterminer s'il est ouvert ou fermé.
- Open|Filtered : Nmap ne peut pas déterminer si le port est ouvert ou filtré.

- Closed|Filtered : Nmap ne peut pas déterminer si le port est fermé ou filtré (rare).

3.2 Les flags TCP

Les flags TCP sont des bits de contrôle dans l'en-tête TCP qui définissent le type et le but d'un paquet. Voici les principaux flags :

- URG (Urgent) : les données sont urgentes et doivent être traitées en priorité.
- ACK (Acknowledgment) : accuse réception des données.
- PSH (Push) : force l'envoi immédiat des données.
- RST (Reset) : réinitialise la connexion — indique généralement une erreur ou un refus.
- SYN (Synchronize) : initie une connexion TCP (première étape du handshake).
- FIN (Finish) : termine proprement une connexion TCP.

3.3 TCP Connect Scan (-sT)

Le scan TCP Connect est le type de scan le plus basique et le plus fiable. Il utilise l'appel système connect() pour établir une connexion complète avec le port cible selon le three-way handshake :

- SYN : Nmap envoie un paquet SYN au port cible.
- SYN-ACK : si le port est ouvert, la cible répond avec SYN-ACK.
- ACK : Nmap envoie un ACK pour compléter la connexion, puis la ferme avec un RST.

Résultats possibles :

- Si SYN-ACK est reçu → le port est ouvert.
- Si RST est reçu → le port est fermé.
- Si aucune réponse ou ICMP unreachable → le port est filtré.

Avantages : fonctionne sans privilèges root, connexion fiable. Inconvénients : plus lent, laisse des traces dans les logs, facilement détectable par les IDS.

```
nmap -sT <target>
```

3.4 TCP SYN Scan / Stealth Scan (-sS)

Également appelé « half-open scan » ou « stealth scan », c'est le type de scan par défaut de Nmap quand il est exécuté avec des privilèges root. Il fonctionne en envoyant un SYN, puis — si SYN-ACK est reçu — envoie immédiatement un RST pour abandonner la connexion sans la finaliser.

Avantages : plus rapide, plus discret, moins de traces dans les logs. Inconvénients : nécessite les droits root, peut être détecté par les IDS modernes.

```
sudo nmap -sS <target>
```

3.5 UDP Scan (-sU)

Le scan UDP permet de découvrir les services UDP ouverts (DNS port 53, SNMP port 161, DHCP ports 67/68…). UDP étant un protocole sans connexion, ce scan fonctionne différemment : Nmap envoie un paquet UDP et analyse la réponse.

- Si une réponse UDP est reçue → le port est ouvert.
- Si ICMP port unreachable (type 3, code 3) est reçu → le port est fermé.
- Si aucune réponse → le port est Open|Filtered.

Inconvénients : très lent, nécessite les droits root, les pare-feux limitent souvent le taux de réponses ICMP.

```
sudo nmap -sU <target>
sudo nmap -sU --top-ports 20 <target>   (optimisé sur les 20 ports les plus courants)
```

3.6 Tableau comparatif des types de scans

Type de scan	Commande	Privilèges	Vitesse	Discrétion
TCP Connect	nmap -sT	Non requis	Moyen	Faible
TCP SYN	sudo nmap -sS	Root requis	Rapide	Moyenne
UDP	sudo nmap -sU	Root requis	Très lent	Moyenne

4. Scans avancés avec Nmap

4.1 Null Scan (-sN)

Le null scan est un scan dans lequel la sonde envoyée par Nmap ne contient aucun flag TCP (tous les flags sont à zéro). Nmap s'attend à ce que le système cible ne réponde pas pour en déduire que le port est ouvert. Si une réponse de type RST est reçue, alors le port est fermé. En présence d'un pare-feu qui bloque le paquet, Nmap présente l'état comme Open|Filtered.

```
nmap -sN <target>
```

4.2 FIN Scan (-sF)

Le FIN scan utilise le flag FIN TCP. Comme pour le null scan, l'absence de réponse indique un port ouvert. Une réponse de type [RST, ACK] indique un port fermé. Un pare-feu peut bloquer la requête, entraînant un état Open|Filtered.

```
nmap -sF <target>
```

4.3 Xmas Scan (-sX)

Le Xmas scan utilise une combinaison de trois flags TCP simultanément : FIN, PSH et URG. Cette combinaison lui vaut son nom car les flags « s'allument comme un arbre de Noël ». Les règles d'interprétation des réponses sont identiques au FIN scan.

```
nmap -sX <target>
```

4.4 ACK Scan (-sA)

L'ACK scan utilise le flag ACK. Le système cible répond toujours avec un RST, quel que soit l'état du port. Ce scan n'indique donc pas si un port est ouvert ou fermé, mais permet de découvrir les règles de filtrage d'un pare-feu en identifiant les ports non bloqués.

```
nmap -sA <target>
```

4.5 Window Scan (-sW)

Très similaire à l'ACK scan, le Window scan examine en plus le champ Window size du paquet RST retourné. Certains systèmes renvoient une taille de fenêtre différente selon que le port est ouvert ou fermé, ce qui permet une détection plus fine.

```
nmap -sW <target>
```

4.6 Custom Scan (--scanflags)

Il est possible de combiner plusieurs flags TCP de manière personnalisée via la commande suivante :

```
nmap --scanflags <FLAGS> <target>
```

Exemple : combinaison de RST, SYN et FIN simultanément sur la cible 10.10.15.10 :

```
nmap --scanflags RSTSYNFIN 10.10.15.10
```

La connaissance du rôle de chaque flag TCP est essentielle pour savoir quels flags combiner afin d'obtenir les meilleurs résultats.

5. Fine-Tuning : Portée et Performance

5.1 Spécification des ports

Nmap offre plusieurs options pour cibler précisément les ports à scanner :

- -p <plage> : spécifie les ports à scanner (ex : -p 22,80,443 ou -p 1-1000).
- -p- : scanne tous les 65 535 ports TCP.
- --top-ports <N> : scanne les N ports les plus courants (ex : --top-ports 100).
- -F : Fast scan — scanne les 100 ports les plus courants.

5.2 Templates de timing (-T)

Nmap propose six templates de timing numérotés de 0 à 5 :

Option	Nom	Description
-T0	Paranoid	Très lent (300 s entre paquets), pour éviter les IDS
-T1	Sneaky	Lent et discret (15 s entre paquets)
-T2	Polite	Réduit la charge réseau

-T3	Normal	Timing par défaut, équilibré
-T4	Aggressive	Rapide, pour réseau fiable et rapide
-T5	Insane	Très rapide, sacrifie la précision

5.3 Autres options de performance

- --min-parallelism / --max-parallelism : nombre de probes parallèles.
- --host-timeout : temps maximum pour scanner un hôte.
- --min-rate / --max-rate : taux minimum/maximum de paquets par seconde.
- -Pn : désactive le ping (traite tous les hôtes comme actifs).

Exemples de commandes optimisées :

```
sudo nmap -sS -T4 --top-ports 1000 <target>   (scan rapide)
sudo nmap -sS -p- -T4 --min-rate 1000 <target> (scan complet rapide)
sudo nmap -sS -T2 -p 22,80,443 <target>        (scan discret)
```

6. Détection des vulnérabilités et sécurisation

6.1 Le Nmap Scripting Engine (NSE)

Le NSE est la fonctionnalité la plus puissante de Nmap. Il permet d'exécuter des scripts Lua qui automatisent des tâches d'audit avancées, notamment la détection de vulnérabilités connues (CVE).

```
nmap --script=vuln   <target>          (vulnérabilités générales)
nmap --script=safe   <target>          (scripts non intrusifs)
nmap --script=smb-vuln-ms17-010 <ip>   (EternalBlue / WannaCry)
nmap --script=ssl-heartbleed    <ip>   (Heartbleed OpenSSL)
nmap --script=ftp-anon          <ip>   (FTP anonyme)
nmap --script=http-methods      <ip>   (méthodes HTTP dangereuses)
```

6.2 Export des résultats

```
nmap -oX rapport.xml <cible>   (format XML pour autres outils)
nmap -oN rapport.txt <cible>   (texte lisible)
nmap -oA rapport     <cible>   (tous les formats à la fois)
```

6.3 Plan de sécurisation après audit

Une fois le rapport d'audit établi, les actions concrètes de sécurisation à mener sont les suivantes :

Fermer les ports inutiles :

- Désactiver les services non nécessaires (Telnet, FTP non sécurisé, etc.).
- Configurer le pare-feu (iptables, ufw, firewalld) pour bloquer les ports exposés.

Patch Management :

- Identifier les services vulnérables avec les versions détectées.
- Prioriser les corrections par score CVSS (Critical > High > Medium > Low).
- Mettre à jour les services impactés après tests en environnement de préproduction.

Durcissement (Hardening) :

- Désactiver les comptes par défaut et les accès non sécurisés.
- Forcer le chiffrement TLS sur tous les services exposés.
- Mettre en place un filtrage par adresse IP si possible.

Re-test et documentation :

- Relancer un scan Nmap après correction pour vérifier que les failles sont bien corrigées.
- Documenter toutes les vulnérabilités trouvées et les actions correctives effectuées.

7. Outils complémentaires

Outil	Rôle
Zenmap	Interface graphique officielle de Nmap — génère des cartes réseau visuelles
OpenVAS / Greenbone	Scanner de vulnérabilités complet, peut importer les résultats XML de Nmap
Metasploit	Exploitation des vulnérabilités identifiées par Nmap (pentest)
Wireshark	Analyse du trafic réseau en temps réel
Nikto	Scanner de vulnérabilités spécialisé pour les applications web
arp-scan	Scan réseau local via requêtes ARP, complémentaire à Nmap

Conclusion

Nmap est bien plus qu'un simple scanner de ports : c'est un outil polyvalent et incontournable de la cybersécurité moderne. À travers ses multiples fonctionnalités — découverte d'hôtes, cartographie réseau, détection de services, et identification de vulnérabilités via le NSE — il permet aux administrateurs système et aux professionnels de la sécurité d'obtenir une vision complète et précise de leur infrastructure.

La maîtrise de Nmap, couplée à une utilisation responsable et éthique (uniquement sur des réseaux dont on est propriétaire ou sur lesquels on dispose d'une autorisation explicite), constitue un fondement solide pour toute démarche d'audit de sécurité et de sécurisation des systèmes d'information.